Active Directory Attack Lab
Kerberoasting Risk Assessment and Group Policy Hardening
IBM Cybersecurity Program — Educational Project

Project Overview

This project demonstrates how **Kerberoasting** — a post-exploitation technique targeting Kerberos service tickets — works in an isolated, synthetic Windows domain, and how **Group Policy Objects (GPOs)** and service-account hardening eliminate the attack surface.

The accompanying Flask web application provides an interactive dashboard for risk scenario review, defensive control scoring, and automated risk assessment.

> **Educational Scope:** All lab work is performed in an offline, isolated virtual environment using synthetic identities. No production systems, real credentials, or live networks are involved.

Project Structure

```
.
├── app.py                          # Flask application
├── requirements.txt                # Python dependencies
├── README.md                       # This file
│
├── templates/                      # Jinja2 HTML templates
│   ├── base.html
│   ├── index.html                  # Dashboard
│   ├── scenarios.html              # Risk scenarios list
│   ├── checklist.html              # Defensive checklist
│   ├── risk_assessment.html        # Risk scoring form
│   └── error.html
│
├── static/
│   ├── css/style.css               # Dark-theme stylesheet
│   └── js/main.js                  # Checklist & UI helpers
│
├── ad_lab/
│   └── AD_Lab_Setup.md             # Windows domain lab guide
│
├── hardening/
│   └── Security_Hardening_Baseline.md   # GPO & service account controls
│
├── docs/
│   └── kerberoasting_project_report.html  # Full HTML project report
│
├── tests/
│   └── test_app.py                 # Pytest test suite
│
├── logs/                           # Runtime logs (gitignored)
└── submission/
    └── Evidence_Checklist.md       # Submission evidence tracker
```

Quick Start

Prerequisites
- Python 3.10 or later
- `pip`

Installation

```bash
# 1. Clone or extract the project
cd ad-attack-lab

# 2. Create virtual environment
python -m venv venv

# 3. Activate virtual environment
# Windows:
venv\Scripts\activate
# macOS/Linux:
source venv/bin/activate

# 4. Install dependencies
pip install -r requirements.txt

# 5. Create logs directory
mkdir logs

# 6. Run the application
python app.py
```

Access
Open your browser at: **http://127.0.0.1:5000**

The application runs locally only (127.0.0.1) — it does not bind to external interfaces.

Application Features

Feature	Route	Description
Dashboard	`/`	Overview stats, scenario table, lab info
Risk Scenarios	`/scenarios`	6 Kerberoasting attack vectors with mitigations
Defensive Checklist	`/checklist`	10-item control checklist with scoring
Risk Assessment	`/risk-assessment`	Interactive form-based risk scoring
Export CSV	`/export/csv`	Download all risk scenarios as CSV
Export Checklist CSV	`/export/checklist-csv`	Download checklist results as CSV
JSON API	`/api/scenarios`	Machine-readable scenarios
JSON Stats	`/api/stats`	Summary statistics endpoint

Lab Documentation

Document	Location	Description
AD Lab Setup	`ad_lab/AD_Lab_Setup.md`	Virtual lab creation, domain setup, synthetic accounts
Hardening Baseline	`hardening/Security_Hardening_Baseline.md`	GPO, gMSA, AES, audit policies, PS logging
Project Report	`docs/kerberoasting_project_report.html`	Full academic project report
Evidence Checklist	`submission/Evidence_Checklist.md`	Submission readiness tracker

Running Tests

```bash
# Install test dependencies
pip install pytest
```

```
# Run all tests
pytest tests/ -v

# Run with coverage report
pip install pytest-cov
pytest tests/ -v --cov=app --cov-report=term-missing
```

Security Notes

- The application runs on `127.0.0.1` (localhost) only by default
- CSRF protection is enabled on all POST forms via Flask-WTF
- All user inputs are sanitised with `bleach` before use
- No credentials, keys, or sensitive data are stored by this application
- `DEBUG=False` is enforced in the entry point
- The `SECRET_KEY` should be set via environment variable in any non-local deployment

---

Lab Safety Requirements

- [ ] VMs isolated on Host-Only network (no internet bridge)
- [ ] All identities are synthetic (`lab.local` domain)
- [ ] Lab VMs not connected to any corporate network
- [ ] No real passwords or production SPNs used
- [ ] Evaluation-only OS licenses used for VMs

IBM Program Rubric Alignment

Rubric Criterion	Implementation
Problem identification	Risk scenarios with CVSS scores and descriptions
Technical depth	Kerberos mechanics, SPN analysis, GPO hardening details
Defensive methodology	10-control checklist, risk assessment scoring
Documentation quality	README, AD lab guide, hardening baseline, project report
Code quality	Flask with CSRF, input validation, error handlers, logging
Testing	Pytest suite covering routes, scoring, and exports
Ethical compliance	Defensive focus, isolated lab, synthetic identities only

---

Disclaimer

This project is created for **educational purposes** as part of the IBM Cybersecurity Program.
All techniques described are for understanding defensive security controls.
No unauthorised access, credential theft, persistence, or attacks on live systems are performed or intended.